



用户隐私增强的权限管理技术要求

第 1 部分：总则

Technical requirements for permission management
to enhance user privacy

Part 1: General

编制单位：移动智能终端生态专业委员会 · 应用安全组

2025 年 9 月

目录

前 言	II
1 范围	4
2 规范性引用文件	4
3 术语和定义	4
3.1 移动智能终端 mobile intelligent terminal	4
3.2 移动互联网应用程序 mobile internet application	4
3.3 移动互联网应用程序客户端 mobile internet application client	4
3.4 侧载应用 sideload application	4
3.5 增强确认模式 enhanced confirmation mode	4
3.6 用户隐私增强的权限管理技术要求 technical requirements for permission management to enhance user privacy	5
3.7 安全控件 security components	5
3.8 数据选择器 picker	5
3.9 运行时权限 runtime permissions	5
3.10 特殊权限 special permissions	5
3.11 受信任应用程序 trusted application	5
3.12 一般确认模式 normal confirmation mode	6
4 缩略语	6
5 标准架构	6
5.1 概述	6
6 用户隐私增强的权限管理和使用原则	7
6.1 权限申请原则	7
6.2 权限使用原则	8
附录 A	9
安卓权限与安全隐私风险映射表及权限名称清单	9
A.1 安卓权限与安全隐私风险映射表	9
A.2 权限名称清单	10
参考文献	11

前 言

本标准按照 GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》给出的规则起草。

本标准是移动智能终端生态联盟标准之一，《用户隐私增强的权限管理技术要求》系列标准的名称及结构如下：

第1部分：总则；

第2部分：设备和应用通知权限；

第3部分：应用使用情况访问权限；

第4部分：悬浮窗权限；

第5部分：设备管理器权限；

第6部分：默认应用管理权限；

第7部分：无障碍权限；

第8部分：应用内安装权限

第9部分：通讯录读取权限

第10部分：照片读取权限

第11部分：视频读取权限

第12部分：音频读取权限

第13部分：文件读取权限

第14部分：应用列表读取权限

第 15 部分：定位权限

第 16 部分：剪贴板读取权限

第 17 部分：所有文件读取权限

本文件的附录 A 为资料性附录。

本标准由移动智能终端生态联盟应用安全工作组提出并归口。请注意本文件的某些内容可能涉及专利，本文件的发布机构不承担识别这些专利的责任。

本标准起草单位：OPPO 广东移动通信有限公司，北京小米移动软件有限公司，维沃移动通信有限公司，荣耀终端股份有限公司。

用户隐私增强的权限管理技术要求

1. 范围

本标准规定了用户隐私增强的权限管理技术要求，包括权限申请和使用原则、标准架构和系列标准中各部分的详细要求。

本标准适用于金标联盟的安卓应用程序开发者开展权限管理安全机制的设计和开发。

2. 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改版）适用于本文件。

GB/T 25069-2022 信息安全技术 术语

3. 术语和定义

GB/T 25069-2022 中界定的以及下列术语和定义适用于本文件。

3.1

移动智能终端 mobile intelligent terminal

是指能使用无线移动通信技术实现互联网接入，具有能够提供应用程序开发接口的开放操作系统，并能够安装和运行第三方应用程序的移动智能终端。

3.2

移动互联网应用程序 mobile internet application

是指安装在移动智能终端上，能够利用移动智能终端设备上操作系统提供的开发接口，实现某项或某几项特定任务的应用程序，包括移动智能终端预置的应用程序，以及通过网站、应用商店等移动应用分发平台下载、安装和升级的应用程序。

3.3

移动互联网应用程序客户端 mobile internet application client

是指移动互联网应用程序运行在移动智能终端上的应用软件，在客户端打开运行移动互联网应用程序可以获得特定服务。

3.4

侧载应用 sideload application

是指通过调用安卓系统包安装应用（例如使用文件管理器、浏览器、三方商店安装）安装的应用。

3.5

增强确认模式 enhanced confirmation mode

是指用于限制第三方侧载应用（比如：浏览器等）获取敏感权限的模式，将通过系统级权限设置对侧载应用获取无障碍功能或通知侦听器服务等敏感功能与权限进行管理。

3.6

用户隐私增强的权限管理技术要求 technical requirements for permission management to enhance user privacy

是指基于安卓原生权限设置，通过增强确认模式、安全控件、数据选择器等技术对移动互联网应用程序获取敏感个人信息和调用系统安全功能的行为进行管理。

3.7

安全控件 security components

是指一类可供移动互联网应用程序调用的特殊控件，用于对应权限的临时授权。

3.8

数据选择器 picker

是指一类管理特定类型的敏感个人信息的系统组件，特定数据类型包括联系人、照片、视频、音频、文档等。

3.9

运行时权限 runtime permissions

是指安卓原生定义的运行时权限，此类权限授予应用对受限数据的额外访问权限，或允许应用执行对系统和其他应用具有更严重影响的受限操作。

3.10

特殊权限 special permissions

是指安卓原生定义的特殊权限。特殊权限与特定的应用操作相对应，只有平台和原始设备制造商（OEM）可以定义特殊权限。此外，如果平台和 OEM 想要防止有人执行功能特别强大的操作（例如通过其他应用绘图），通常会定义特殊权限。系统会为特殊权限分配 appop 保护级别。

3.11

受信任应用程序 trusted application

是指不需要受到增强确认模式额外管控的应用程序,判断受信任应用程序的方式包括但不限于:判断其是否为受信任包名、受信任应用软件来源、系统签名、系统应用。

3.12

一般确认模式 normal confirmation mode

是指特殊权限的默认授权方式,即终端设备默认允许应用程序使用权限,或默认拒绝并支持应用程序通过 Intent 等方式引导用户从权限管理界面开启权限。

4. 缩略语

下列缩略语适用于本文件。

ECM: 增强确认模式 (Enhanced Confirmation Mode)

5. 标准架构

5.1 概述

终端上的应用程序在安装时会向用户请求各种权限,如通讯录访问权限、相册访问权限等;用户可在安装时或在应用的设置中选择是否授予这些权限。终端系统会根据用户授予的权限来决定应用程序是否可以访问相应的资源。

用户隐私增强的权限管理技术可以防止应用程序对未经授权的数据(特别是敏感个人信息)访问,确保系统安全稳定运行,减少隐私泄露和数据滥用。常见针对权限攻击导致的安全隐私风险,可参考附录 A.1。

《用户隐私增强的权限管理技术要求》系列标准包括但不限于以下内容:

- 1) 总则
- 2) 设备和应用通知
- 3) 应用使用情况访问
- 4) 悬浮窗
- 5) 设备管理器
- 6) 默认应用管理
- 7) 无障碍
- 8) 应用内安装
- 9) 通讯录读取
- 10) 照片读取
- 11) 视频读取
- 12) 音频读取
- 13) 文件读取
- 14) 应用列表读取
- 15) 定位
- 16) 剪贴板读取
- 17) 所有文件读取

其中, 系列标准的第 2 至第 8 部分描述了用于增强系统安全功能的相关权限的管理技术要求; 系列标准的第 9 至第 17 部分描述了用于提升敏感个人信息保护的相关权限管理技术要求。

该系列标准结构如图 1 所示。

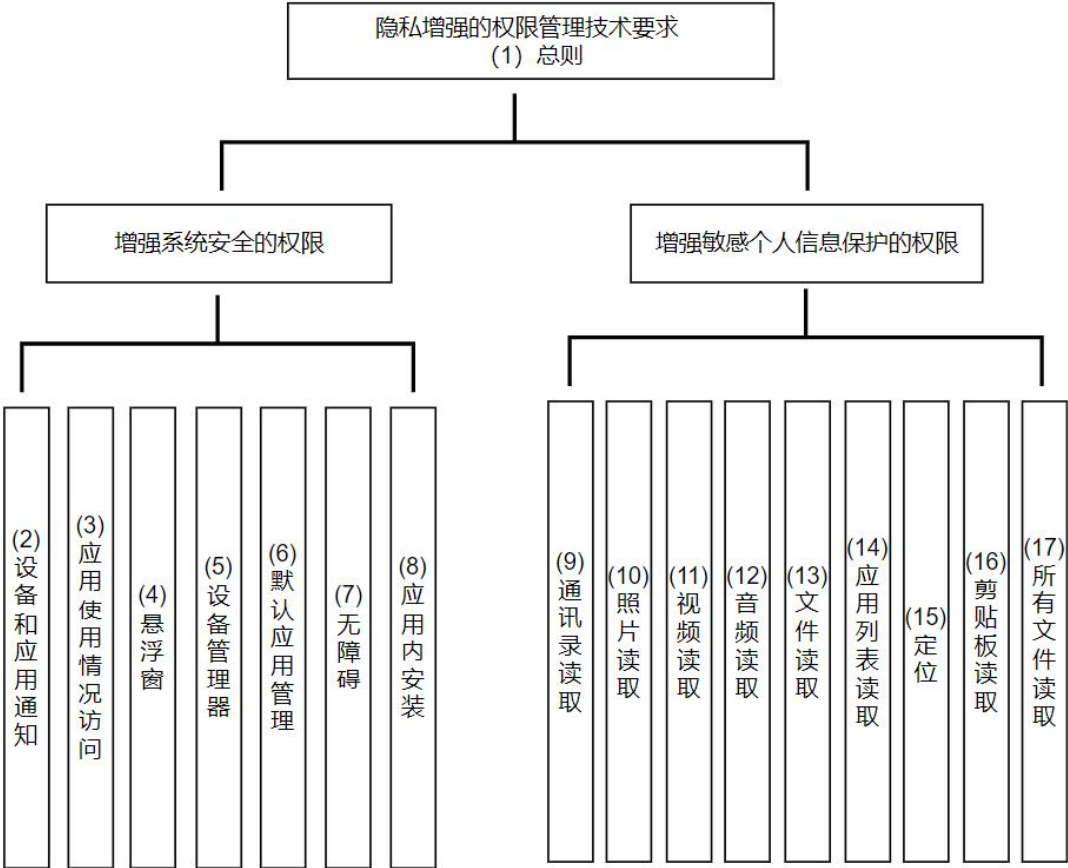


图 1 用户隐私增强的权限管理技术要求系列标准结构图

6. 用户隐私增强的权限管理和使用原则

6.1 权限申请原则

权限申请应遵循以下原则：

- a) 权限的申请应遵循最小必要原则，即只申请与业务功能相关的权限，不应过度申请权限。
 - i. 对于 SDK 等外部代码的引用，APP 应确认其相关权限的申请同样满足最小化原则，限制 SDK 过度申请权限。如 APP 的业务场景中，不包含位置相关场景，则不应申请位置权限。
 - ii. 尽量采用其他无需权限的操作来实现相应功能（如：通过 intent 拉起系统 UI 界面由用户交互、应用自己生成 uuid 代替设备 ID 等）；

- b) 权限申请完整。应用所需权限（包括应用调用到的三方库依赖的权限）都要逐个在应用的 `config.json` 中按格式声明；
- c) 满足用户可知。应用申请的敏感权限的目的需要真实准确告知用户；
- d) 权限就近申请。应用在用户触发相关业务功能时，就近提示用户授予实现此功能所需的权限。

6.2 权限使用原则

权限使用应遵循以下原则：

- a) 权限的使用应遵循最小必要原则，即应合理使用申请的权限，不应滥用权限，且实际使用的权限不应超出告知同意的范围。
- b) APP 宜优先采用系统自身功能，代替调用相关敏感权限。在存在替代功能实现方式的情况下，不应以提升用户体验为由，强迫用户授予权限。
- c) 权限不扩散。在用户未授权的情况下，不允许提供给其他应用使用。
- d) 应用自定义权限防止重名。建议以包名为前缀来命名权限，防止跟系统定义的权限重名。

附录 A

(资料性附录)

安卓权限与安全隐私风险映射表及权限名称清单

A.1 安卓权限与安全隐私风险映射表

本框架中涉及的各项权限与安全隐私风险的映射关系如下表所示。

安全领域	风险类别	对应权限
敏感个人信息	个人隐私泄露	定位权限 通讯录读取权限 照片读取权限 视频读取权限 音频读取权限 文件读取权限 应用列表读取权限 所有文件读取权限
	AI 语音、视频、音频伪造	照片读取权限 视频读取权限 音频读取权限
	用户画像、广告推送滥用	应用列表读取权限 定位权限 设备和应用通知权限 应用使用情况访问权限
系统安全	电信诈骗	通讯录读取权限 应用内安装权限 无障碍权限 应用使用情况访问权限
	广告、黑灰产	应用内安装权限 无障碍权限
	系统攻击	应用使用情况访问权限 设备和应用通知权限 悬浮窗权限 所有文件读取权限 应用内安装权限 无障碍权限 设备管理器权限 默认应用管理权限
	应用恶意保活、恶意骚扰等	设备和应用通知权限

A. 2 权限名称清单

本框架中涉及的各项权限在操作系统中对应的权限名称如下表所示。

权限	权限名称	备注
设备和应用通知权限	android.permission.BIND_NOTIFICATION_LISTENER_SERVICE	
应用使用情况访问权限	android.permission.PACKAGE_USAGE_STATS android.permission.LOADER_USAGE_STATS	
悬浮窗权限	android.permission.SYSTEM_ALERT_WINDOW	
设备管理器权限	android.permission.BIND_DEVICE_ADMIN	
默认应用管理权限	/	泛权限，设置开关管控
无障碍权限	/	泛权限，设置开关管控
应用内安装权限	android.permission.REQUEST_INSTALL_PACKAGES	
通讯录读取权限	android.permission.READ_CONTACTS	
照片读取权限	android.permission.READ_MEDIA_IMAGES android.permission.READ_MEDIA_VISUAL_USER_SELECTED	
视频读取权限	android.permission.READ_MEDIA_VIDEO android.permission.READ_MEDIA_VISUAL_USER_SELECTED	
音频读取权限	android.permission.READ_MEDIA_AUDIO	
文件读取权限	android.permission.READ_EXTERNAL_STORAGE	
应用列表读取权限	android.permission.QUERY_ALL_PACKAGES com.android.permission.GET_INSTALLED_APPS	
定位权限	android.permission.ACCESS_BACKGROUND_LOCATION android.permission.ACCESS_FINE_LOCATION android.permission.ACCESS_COARSE_LOCATION	
剪贴板读取权限	/	厂商自定义权限
所有文件读取权限	android.permission.MANAGE_EXTERNAL_STORAGE	

参考文献

- [1] 《中华人民共和国网络安全法》
- [2] 《电信和互联网用户个人信息保护规定》
- [3] GB/T34975-2017 信息安全技术 移动智能终端应用软件安全技术要求和测试评价方法
- [4] GB/T 34978-2017 信息安全技术 移动智能终端个人信息保护技术要求
- [5] GB/T22239-2019 信息安全技术 网络安全等级保护基本要求
- [6] GB/T 35273 信息安全技术 个人信息安全规范
- [7] YD / T 2694-2014 移动互联网应用安全防护要求
- [8] YD / T 2960-2015 移动互联网术语
- [9] YDT 2587-2013 移动互联网应用商店安全防护要求